

IT Security Guidelines

Information Security, Infrastructure Protection & Risk Mitigation Policy

Document Reference: IT-SEC-2025-01

Effective Date: January 1, 2025

Approved By: Chief Information Security Officer (CISO)

1. EXECUTIVE SUMMARY & SCOPE

KnowledgeOS Enterprise is dedicated to safeguarding company systems, proprietary artificial intelligence infrastructure, and client data against cybersecurity threats. This Information Technology Security Policy establishes baseline operational standards for identity management, infrastructure access, remote work protocols, data classification, and incident response.

This policy applies to all full-time, part-time, temporary, and third-party contract personnel accessing KnowledgeOS Enterprise hardware, cloud environments, networks, or digital assets globally.

2. IDENTITY MANAGEMENT & PASSWORD REQUIREMENTS

Robust password hygiene serves as the initial line of defense against unauthorized system access. All user credentials must adhere to enterprise complexity standards enforcement via single sign-on (SSO) and Active Directory policies.

Password Policy Parameters

Security Parameter	Standard Policy Requirement
Minimum Password Length	16 characters minimum (Passphrases strongly recommended).
Complexity Requirements	Must include uppercase, lowercase, numerical, and special characters (!@#\$\$%^&*).
Expiration & Rotation	90-day mandatory password rotation for standard accounts; 45-day rotation for privileged admin accounts.
Password History	Prevents reuse of the last 12 previously utilized passwords.
Password Manager Mandate	All credentials must be stored within the company-issued enterprise password vault (1Password Enterprise). Storing plain-text passwords in browser storage, text files, or sticky notes is strictly prohibited.

3. MULTI-FACTOR AUTHENTICATION (MFA)

Multi-Factor Authentication (MFA) is mandatory across all KnowledgeOS Enterprise cloud portals, internal networks, VPN connections, and SaaS platforms without exception.

- **Approved Authentication Methods:** Hardware FIDO2 Security Keys (YubiKey) or Hardware/Software Time-based One-Time Password (TOTP) authenticator applications (Okta Verify, Google Authenticator).
- **Prohibited Authentication Methods:** SMS-based or voice-call authentication methods are strictly prohibited due to SIM-swapping vulnerabilities.
- **Push Notification Safety:** "MFA Fatigue" or prompt spamming must be reported immediately. Users must carefully review geo-location and IP prompts prior to approving login pushes.

4. EMAIL SECURITY & PHISHING PREVENTION

Email remains the primary entry point for sophisticated social engineering, spear-phishing, and malware delivery. Employees must exercise heightened caution when handling external communications.

Phishing Defense Guidelines

KnowledgeOS Enterprise IT Security conducts unannounced phishing simulations monthly. Employees who fail three consecutive simulated phishing tests will be required to undergo mandatory cybersecurity re-training.

Key Email Safety Rules

- **External Sender Indicators:** Emails received from external domains display an [EXTERNAL SENDER] banner. Exercise extreme caution before opening links or attachments within these messages.
- **Suspicious Links & Attachments:** Never click unverified embedded links or open executable files (.exe, .scr, .bat, macro-enabled .docm) attached to emails. Hover over hyperlinked text to verify destination URLs.
- **Reporting Phishing:** Click the "Report Phishing" button in Outlook/Gmail or forward suspicious messages immediately to phishing@knowledgeos.io.

5. WORKSTATION & DEVICE SECURITY

All devices connecting to KnowledgeOS networks or processing company data must be enrolled in the enterprise Endpoint Detection & Response (EDR) and Mobile Device Management (MDM) platforms.

Device Requirements

- **Full Disk Encryption:** BitLocker (Windows) or FileVault (macOS) encryption must remain enabled with AES-256 standards at all times.
- **Automatic Lock Screen:** Workstations must be configured to lock automatically after 5 minutes of inactivity. Users must manually lock screens (Win+L / Cmd+Ctrl+Q) when stepping away from their desk.
- **Patch Management:** Operating system and software security updates are pushed automatically by IT. Required reboots must be completed within 48 hours of notification.
- **Unattended Physical Hardware:** Company laptops must never be left unattended in public places, unlocked vehicles, or unmonitored conference rooms.

6. VPN & NETWORK CONNECTIVITY

Secure network connectivity is essential to maintain data integrity across distributed and remote operational environments.

VPN Policy Framework

- **Mandatory VPN Connection:** All company devices accessing internal repositories, database clusters, or staging servers from public or remote Wi-Fi networks must connect via the KnowledgeOS GlobalProtect VPN.
- **Public Wi-Fi Risks:** Conducting company business on open, unencrypted public Wi-Fi networks without an active corporate VPN connection is strictly forbidden.
- **Split Tunneling Restrictions:** Unauthorized modification or bypassing of VPN routing rules or DNS settings is prohibited.

7. SOFTWARE INSTALLATION & SHADOW IT RULES

Unvetted software applications introduce significant supply-chain, licensing, and malware risks.

Software Governance Guidelines

- **Approved Software Catalog:** Employees may only install applications made available via the KnowledgeOS Self-Service Portal (Managed Software Store).
- **Administrative Rights:** Standard user accounts do not possess administrative privilege for arbitrary software installations. Requests for temporary elevated rights must be submitted to IT Service Desk.
- **Third-Party Generative AI Tools:** Inputting proprietary source code, internal confidential documents, or customer dataset samples into unapproved external AI platforms (e.g., non-enterprise ChatGPT, public LLM wrappers) is strictly prohibited.

8. ENTERPRISE DATA CLASSIFICATION MODEL

To ensure proportionate access control and protective encryption, information owned or processed by KnowledgeOS Enterprise is categorized into four classification levels:

Level	Classification	Examples	Handling & Storage Rules
1	Public	Marketing brochures, public documentation, press releases.	No restriction; public distribution allowed.
2	Internal	Internal announcements, org charts, internal guidelines.	Restricted to employees; require standard authentication.
3	Confidential	Customer PII, non-public source code, financial reports.	Encrypted in transit & at rest; restricted role-based access (RBAC).
4	Restricted	Production AI model weights, API private keys, strategic M&A plans.	Strict Need-To-Know; CISO approval + Hardware Security Module (HSM) required.

9. REMOTE WORK SECURITY PROTOCOLS

Remote and hybrid work arrangements require equal security vigilance as corporate office environments.

- **Physical Privacy:** Ensure computer monitors are positioned to prevent visual eavesdropping ("shoulder surfing") by unauthorized individuals in public or shared living areas. Privacy screens are mandatory during travel.
- **Prohibition of Personal Hardware:** Work tasks, enterprise communications, and code development must be conducted exclusively on KnowledgeOS-managed devices. Processing corporate data on personal laptops or smartphones is strictly prohibited.
- **Secure Disposal of Physical Documents:** Physical documents containing confidential data must be shredded prior to disposal. High-security shredding bins are available at all corporate facilities.

10. INCIDENT REPORTING & EMERGENCY ESCALATION

Rapid detection and containment of potential security incidents minimize operational disruption and legal liability.

Report Instantly — Zero Retaliation Policy

If you suspect your device, password, or account has been compromised, or if you accidentally clicked a malicious link or lost a company laptop, report it immediately to Security Operations. Employees who report potential security breaches promptly will not face disciplinary action for the report itself.

Incident Reporting Channels

1. **Security Operations Center (SOC) 24/7 Hotline:** +1 (800) 555-KOS-SEC (Ext. 911)
2. **Urgent Slack Channel:** #security-incidents (Monitored 24/7)
3. **Security Incident Email:** security@knowledgeos.io

11. CYBERSECURITY BEST PRACTICES QUICK SUMMARY

- **Always Lock Your Workstation:** Lock screens whenever moving away from your desk.
- **Verify Requests for Sensitive Actions:** Double-check unusual requests for wire transfers, credential changes, or database dumps via a separate trusted communication channel.
- **Keep Devices Updated:** Reboot devices regularly to apply critical security patches.
- **Use Enterprise Vaults:** Never share passwords via Slack, email, or unencrypted text messages.